

Présentation de la PKI

Public Key Infrastructure

Par Louis MEDO & Amine KADA.

Sommaire

1. Qu'est-ce qu'une PKI ?
2. Les 3 acteurs du système
3. Le Certificat X.509
4. Le cycle de vie d'une demande
5. La Révocation du certificat
6. La Révocation du certificat
7. Exemple - Obtention (Serveur Web)
8. Exemple - Vérification (Client Web)
9. PKI Publique vs Interne
10. Comparatif des solutions de PKI interne
11. Mise en pratique

1. Qu'est-ce qu'une PKI ?

- **Problème initial** : La cryptographie asymétrique est vulnérable aux attaques de l'homme du milieu.
- **La solution PKI** : Introduction d'un "tiers de confiance" qui délivre un certificat numérique infalsifiable liant une identité à une clé publique.
- **Cas d'usage** : HTTPS, tunnels VPN, signatures numériques, authentification 802.1X.

2. Les 3 acteurs du système

- **L'Entité finale (Client/Serveur)** : Le demandeur du certificat.
- **L'Autorité d'Enregistrement (AE)** : Le guichet qui vérifie l'identité du demandeur.
- **L'Autorité de Certification (AC)** : Le tiers de confiance qui génère et signe le certificat.

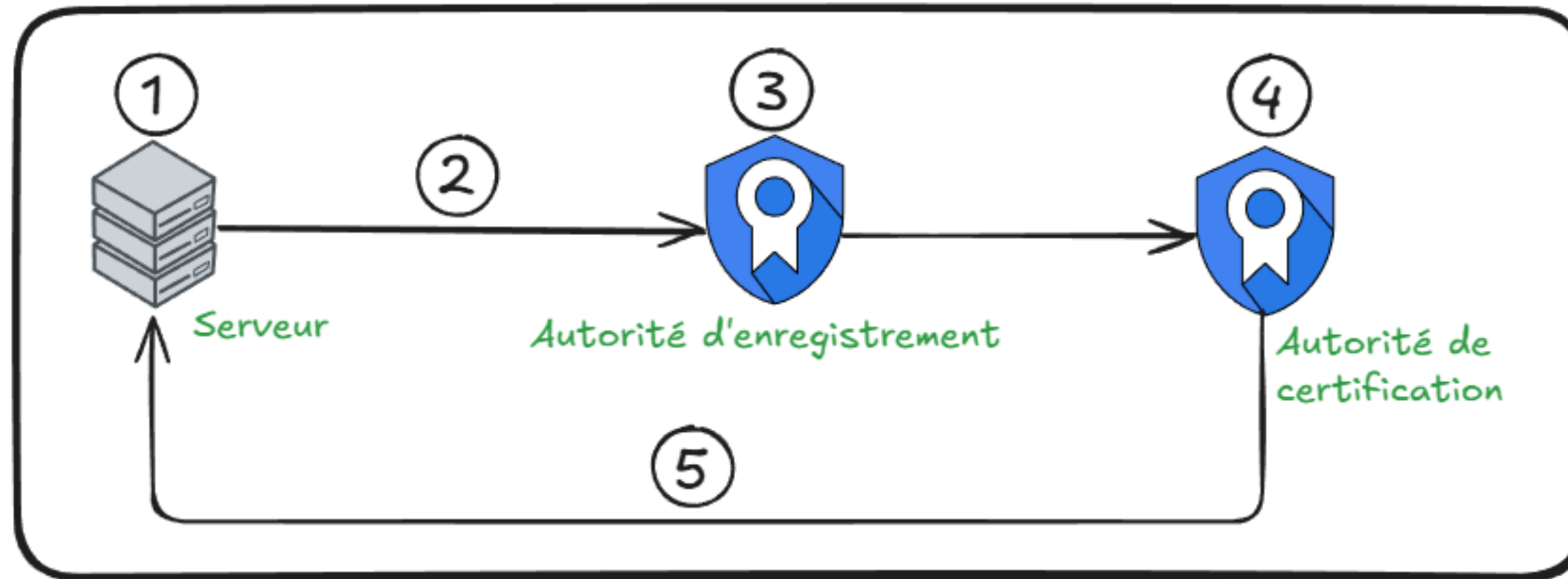
3. Le Certificat X.509

- **Définition** : Format standard de document numérique public.
- **Contenu** :
 - Identité (nom de domaine) et Clé Publique.
 - Dates de validité.
 - Nom et signature cryptographique de l'AC.

```
+-----+
|          Certificat X.509          |
+-----+
| 1. Identité (Nom de domaine, IP..) |
| 2. Clé Publique de l'entité        |
| 3. Dates de validité (Début / Fin) |
| 4. Nom de l'AC émettrice           |
+-----+
|          [ Signature de l'AC ]      |
+-----+
```

4. Le cycle de vie d'une demande

Création d'un certificat auprès d'une autorité de certification



1. Création des clés avec les informations pour la demande de certificat.
2. Envoi du CSR (clé publique + informations).
3. Validation des informations.
4. Création du certificat X.509 et signature avec la clé privée de l'AC.
5. Envoi du certificat X.509 créé.

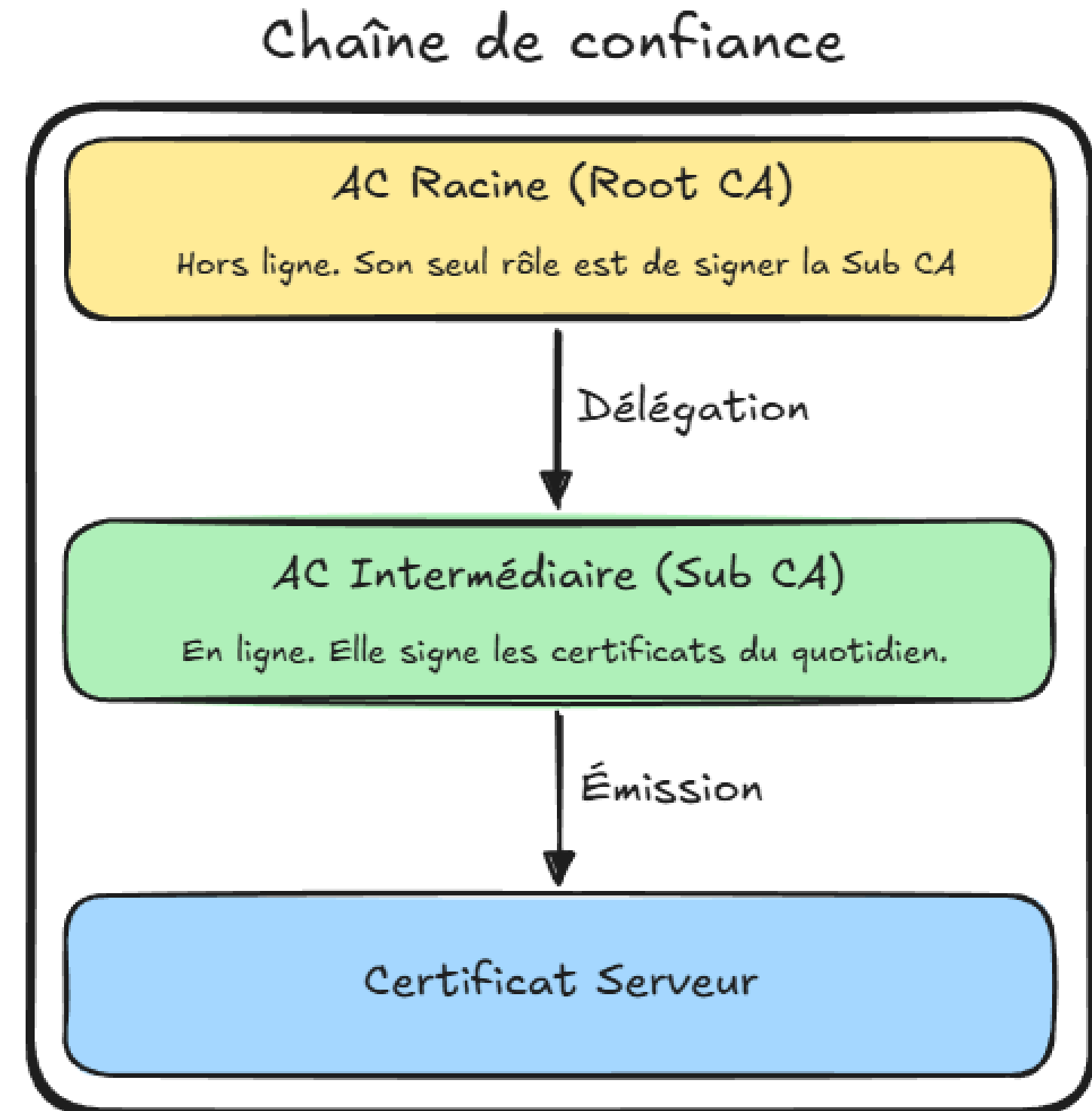
Réalisé par Louis MEDO le 20/09/2026

5. La Révocation du certificat

- **Objectif** : Invalider un certificat avant son expiration (ex: vol de clé privée).
- **CRL** : Liste de révocation statique téléchargée par le client.
- **OCSP** : Interrogation en temps réel de l'AC par le navigateur pour vérifier le statut.

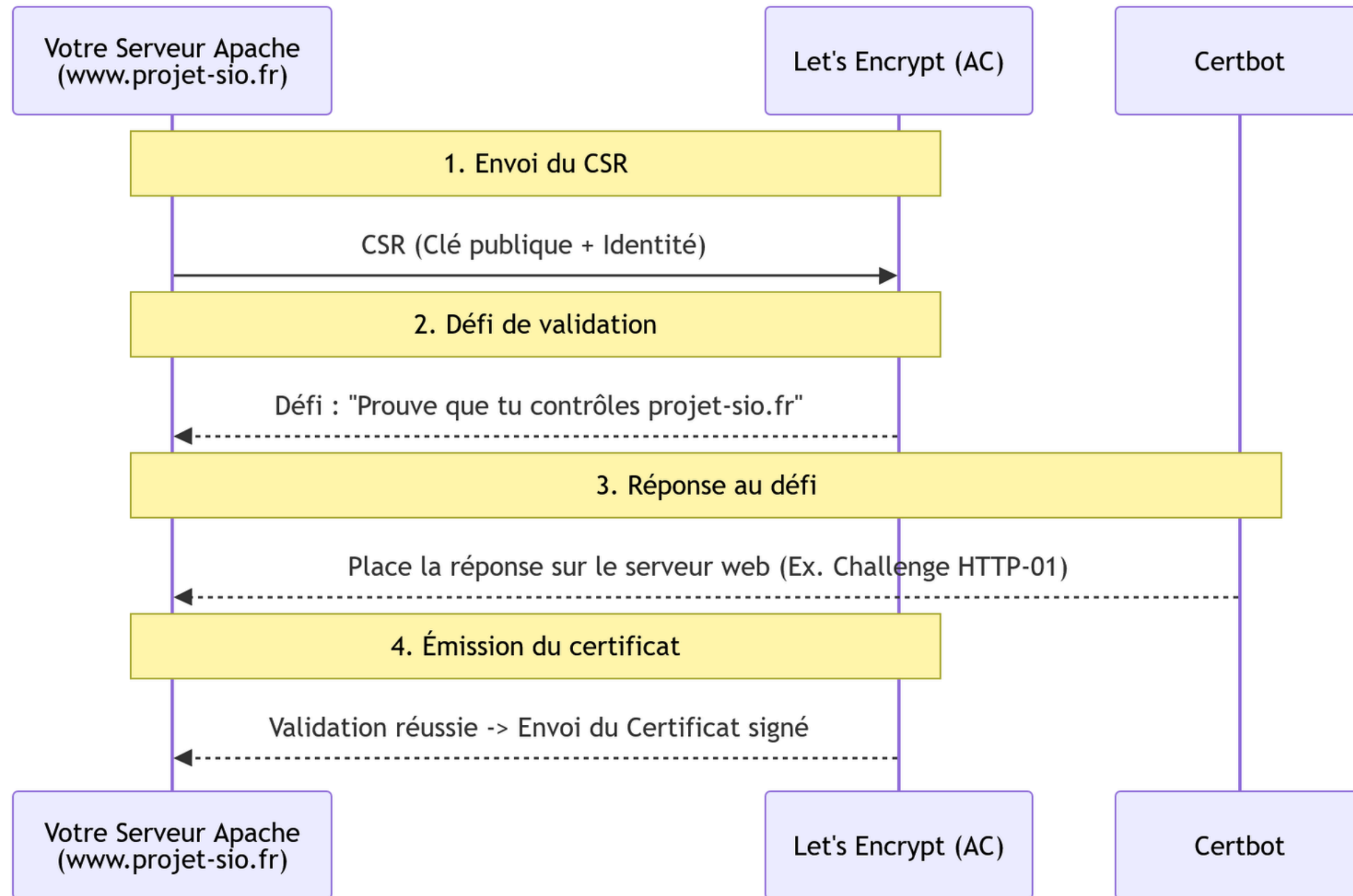
6. La Révocation du certificat

- **Principe hiérarchique :**
Héritage de la confiance par signatures successives.
- **AC Racine :** Préinstallée dans l'OS/Navigateur, ultra-sécurisée et gardée hors-ligne.
- **AC Intermédiaire :** Transmise par le serveur, elle signe le certificat final.

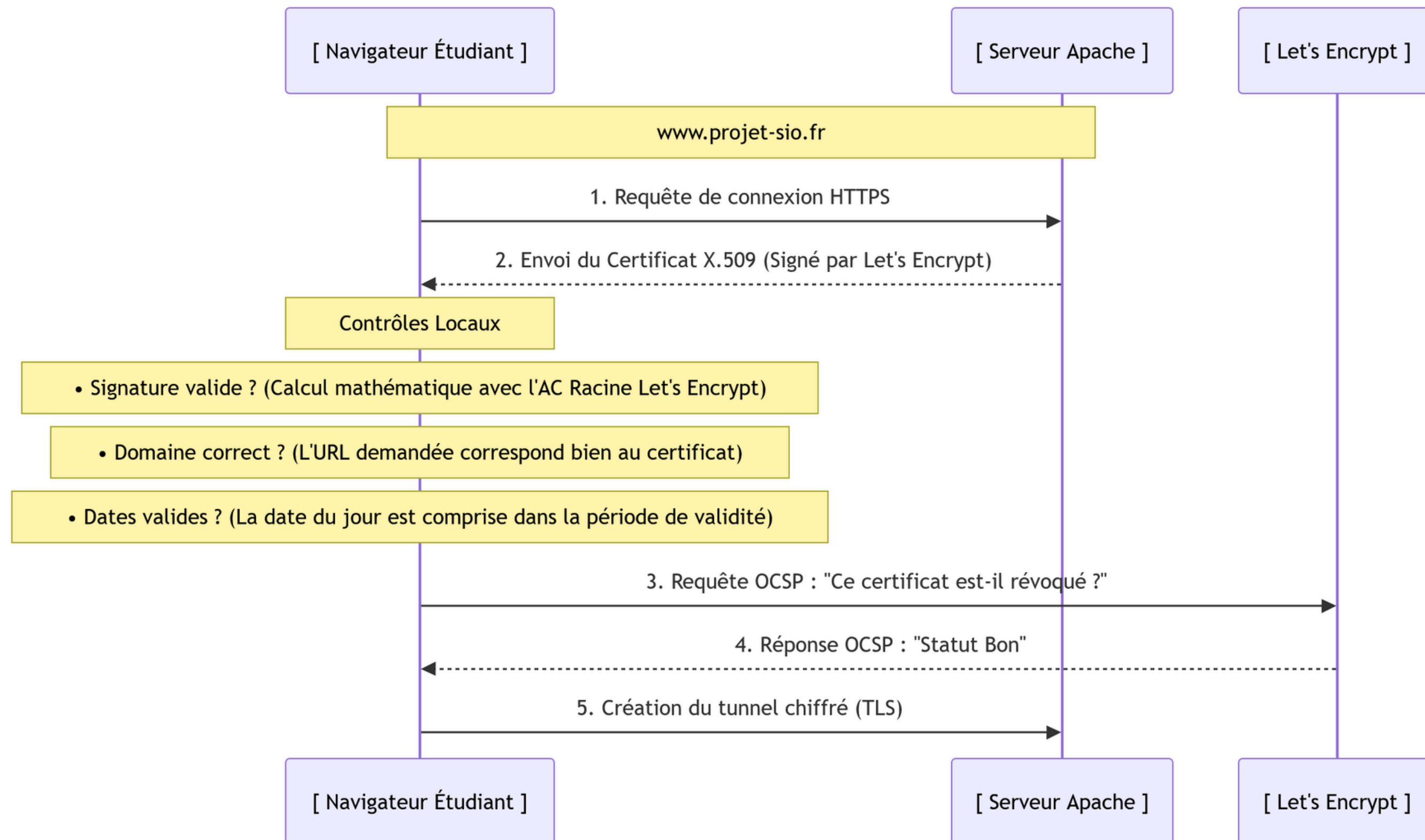


Réalisé par Louis MEDO le 20/09/2026

7. Exemple - Obtention (Serveur Web)



8. Exemple - Vérification (Client Web)



9. PKI Publique vs Interne

- **PKI Publique :**
 - **Définition :** Confiance mondiale (Racines préinstallées). Pour l'Internet grand public.
 - **Exemple :** DigiCert, GlobalSign, Let's Encrypt
- **PKI Interne :**
 - **Définition :** Confiance locale à l'entreprise (Racines à déployer manuellement). Pour intranet, VPN, 802.1X.
 - **Exemple :** AD CS, HashiCorp Vault, Smallstep (Step-CA)

10. Comparatif des solutions de PKI interne

Critères \ Outils	Microsoft AD CS	Step-CA	XCA / OpenSSL
Coûts :	Payant (Inclus avec licence Windows Server)	Gratuit	Gratuit
Philosophie :	Intégration native (Active Directory)	DevOps, API, Infrastructure as Code (sans GUI)	Interface graphique conviviale sur un seul fichier
Modèle :	Propriétaire	Open-Source et Auto-hébergé	Logiciel libre (Client lourd)
Cas d'usage :	Environnement Windows	Certificats éphémères, environnements conteneurisés	Mini-PKI manuelle de test

11. Mise en pratique

Présentation de la PKI (Cours)

Procédure d'installation (AD CS)

Procédure de configuraiton (AD CS)

pki.bts.loutik.fr